b) 生存周期文档要求：文档应详细阐述安全启动和操作的过程，详细说明安全功能在启动、正常操作维护时是否能被撤销或修改，说明在故障或系统出错时如何恢复系统至安全状态。

6.2.2.6 测试

应按GB/T 20271—2006 中 6.2.5.6 的要求，从以下方面对 SSOASS 进行测试：

a) 通过**范围证据和范围分析，高层设计的测试**，一般功能测试和符合性独立测试，确认 SSOASS 的功能与所要求功能的一致性；

b) 所有系统的安全特性，应被全面测试，**包括查找漏洞，如允许违反系统访问控制要求、允许违反资源访问控制要求、允许拒绝服务、允许验证数据进行未授权访问等**；

c) 所有发现的漏洞应被改正、消除或使其无效，并在消除漏洞后重新测试，以证实它们已被消除，且没有引出新的漏洞；

d) 应提供测试文档，详细描述测试计划、测试过程、测试结果。

6.2.2.7 脆弱性评定

应按 GB/T 20271—2006 中 6.2.5.7 的要求，从以下方面对 SSOASS 进行脆弱性评定：

a) **对防止误用的评定，通过对文档的检查，查找 SSOASS 以不安全的方式进行使用或配置而不为人们所察觉的情况；**

b) **对 SSOASS 安全功能强度评估，通过对安全机制的安全行为的合格性或统计结果的分析，证明其达到或超过安全目标要求所定义的最低强度；**

c) **开发者脆弱性分析，确定明显的安全脆弱性的存在，并确认在所期望的环境中所存在的脆弱性不会被利用。**

6.2.3 安全子系统安全管理要求

应根据本安全等级中安全功能技术要求所涉及的安全功能技术要求和安全保证技术要求所涉及的 SSOASS 自身保护、SSOASS 设计和实现等有关内容，按 GB/T 20271—2006 中 6.2.6 的要求，从以下方面实现 SSOASS 的安全管理：

a) 操作规程和规章制度：对安全保证措施所涉及的 SSOASS 自身保护、SSOASS 设计和实现等有关内容，以及与一般的安装、配置等有关的功能，制定相应的操作、运行规程和行为规章制度；

b) SSF 安全功能管理：对 SSOASS 中的每个安全功能模块，根据安全功能技术和安全保证技术所实现的安全功能，实现 SSF 安全功能的管理；

c) **SSF 安全属性管理：对 SSOASS 中的每个安全功能模块，根据安全功能技术和安全保证技术所涉及的安全属性，从管理安全属性、安全的安全属性、静态属性初始化、安全属性终止和安全属性撤销等方面，实现 SSF 安全属性的安全管理；**

d) **SSF 安全数据管理：对 SSOASS 中的每个安全功能模块，根据安全功能技术和安全保证技术所涉及的安全数据，从管理 SSF 数据、SSF 数据界限的管理和安全的 SSF 数据等方面，实现 SSF 安全数据的安全管理。**

7 第三级应用软件系统安全技术要求

7.1 安全功能技术要求

7.1.1 用户身份鉴别

用户身份鉴别包括对一般用户和系统用户（如系统安全员、审计员和安全员）的身份进行标识和鉴

别。应按 GB/T 20271—2006 中 6.3.3.1 的要求，从以下方面设计和实现应用软件系统的用户身份鉴别：

a) 用户注册：对应用软件系统的注册用户，按以下要求设计和实现标识功能：
   1) 凡需进入应用软件系统的用户，应先进行标识（建立注册账号）；
   2) 应用软件系统的用户应以用户名和用户标识符（UID）等信息进行标识，并在应用软件系统的整个生存周期实现用户的唯一性标识，以及用户名或别名、UID 等之间的一致性；
   3) **对提供单点登录的分布式应用软件系统的用户应提供单点标识，且单点标识应具有与常规标识相同的安全性；**
b) 用户登录：对登录到应用软件系统的用户，应按以下要求进行身份的真实性鉴别：
   1) 采用强化管理的口令鉴别/基于令牌的动态口令鉴别/生物特征鉴别/**数字证书鉴别机制**进行用户身份鉴别，并在每次用户登录系统时进行鉴别；**对系统用户应采用两种或两种以上组合的鉴别机制进行身份鉴别；**
   2) 鉴别信息应是不可见的，具有相应的抗攻击能力，并在存储和传输时按GB/T 20271—2006 中 6.3.3.9 **的要求，用加密方法/具有相同安全强度的其他方法进行安全保护；**
   3) 通过对不成功的鉴别尝试的值（包括尝试次数和时间的阈值）进行预先定义，并明确规定达到该值时所应采取的具有规范性和安全性的措施来实现鉴别失败的处理；
   4) **对提供单点登录的分布式应用软件系统的用户应提供单点鉴别，且单点鉴别应具有与常规鉴别相同的安全性；**
c) 用户-主体绑定：对注册到应用软件系统的用户，应按以下要求设计和实现用户-主体绑定功能：
   1) 将用户进程与所有者用户相关联，使用户进程的行为可以追溯到进程的所有者用户；
   2) 将系统进程动态地与当前服务要求者用户相关联，使系统进程的行为可以追溯到当前服务要求者用户。

7.1.2 抗抵赖

抗抵赖包括以下内容：

a) **抗原发抵赖：对于在网络环境进行数据交换的情况，应按 GB/T 20271—2006 中 6.3.3.2a）的要求，通过提供选择性原发证据，实现抗原发抵赖功能；**
b) **抗接收抵赖：对于在网络环境进行数据交换的情况，应按 GB/T 20271—2006 中 6.3.3.2b）的要求，通过提供选择性接收证据，实现抗接收抵赖功能。**

7.1.3 自主访问控制

应按GB/T 20271—2006 中 6.3.3.3 的要求，从以下方面设计和实现应用软件系统的自主访问控制：

a) 自主访问控制功能：命名用户以用户的身份规定并控制对客体的访问，并阻止非授权用户对客体的访问；可以有多个自主访问控制功能，但其访问控制策略必须具有一致性；
b) 自主访问控制策略：提供用户按照确定的访问控制策略对自身创建的客体的访问进行控制的功能，包括：
   1) 客体创建者有权以各种操作方式访问自身所创建的客体；
   2) 客体创建者有权对其他用户进行“访问授权”，使其可对客体拥有者创建的指定客体能按授权的操作方式进行访问；
   3) 客体创建者有权对其他用户进行“授权传播”，使其可以获得将该拥有者的指定客体的访问权限授予其他用户的权限；

4) 客体创建者有权收回其所授予其他用户的“访问授权”和“授权传播”，并对授权传播进行限制，对不可传播的授权进行明确定义，由系统自动检查并限制这些授权的传播；
5) 未经授权的用户不得以任何操作方式访问客体；
6) 授权用户不得以未授权的操作方式访问客体；

c) 操作系统支持的自主访问控制：以文件形式存储和操作的用户数据，在操作系统的支持下，按GB/T 20272—2006 中 4.3.1.2 的要求，可实现文件级粒度的自主访问控制；

d) 数据库管理系统支持的自主访问控制：以数据库形式存储和操作的用户数据，在数据库管理系统的支持下，按GB/T 20273—2006 中 5.3.1.2 的要求，可实现对表级/记录、字段级粒度的自主访问控制；

e) 应用软件系统自身的自主访问控制：在应用软件系统中，通过设置自主访问控制安全机制，可实现文件级粒度的自主访问控制；

f) 分布式系统的自主访问控制：对分布式应用软件系统，应实行统一的自主访问控制安全策略，确保每一个场地的主、客体具有一致的安全属性，并执行相同的访问规则；

g) 网络环境的自主访问控制：对分布于网络环境的应用软件系统，应根据业务应用的实际需要确定实行统一的或各自独立的自主访问控制安全策略。

7.1.4 标记

应按 GB/T 20271—2006 中 6.3.3.4 的要求，从以下方面设计和实现主、客体标记功能：

a) 用户的敏感标记：应在用户建立注册账户后由系统安全员通过 SSOASS 所提供的安全员界面操作进行标记；

b) 客体的敏感标记：应在数据输入到 SSOASS 安全功能的控制范围内时，以默认方式生成或由安全员通过操作界面进行标记；

c) 标记的范围：对分布式应用软件系统，实施相同强制访问控制安全策略的各个场地的主、客体，应以相同的敏感信息进行标记；

d) 分布式系统标记的一致性：对分布式应用软件系统，实施相同强制访问控制安全策略的各个场地的主、客体，应以相同的敏感信息进行标记；

e) 网络环境标记的独立性/一致性：对分布于网络环境的应用软件系统，应根据统一的或各自独立的强制访问控制策略，对主、客体进行统一的或各自独立的敏感信息的标记。

7.1.5 强制访问控制

应按 GB/T 20271—2006 中 6.3.3.5 的要求，从以下方面设计和实现应用软件系统的强制访问控制：

a) 强制访问控制功能：按确定的强制访问控制安全策略，设计和实现相应的强制访问控制功能；可以有多个强制访问控制功能，但其访问控制策略应具有一致性。

b) 操作系统支持的强制访问控制：以文件形式存储和操作的用户数据，在操作系统的支持下，按GB/T 20272—2006 中 4.3.1.4 的要求，可实现文件级粒度的强制访问控制；

c) 数据库管理系统支持的强制访问控制：以数据库形式存储和操作的用户数据，在数据库管理系统的支持下，按 GB/T 20273—2006 中 5.3.1.4 的要求，可实现表/记录、字段级粒度的强制访问控制；

d) 应用软件系统自身的强制访问控制：在应用软件系统中，在 PMI(授权管理基础设施)支持下，可实现文件级粒度的强制访问控制；

e) 强制访问控制的范围：应将强制访问控制的范围限定在所定义的主体与客体；

f) 权限分离与最小授权：将系统的常规管理、与安全有关的管理以及审计管理，分别由系统管理

员、系统安全员和系统审计员来承担，按最小授权原则分别授予它们各自为完成自己所承担任务所需的最小权限，并在它们之间形成相互制约的关系；

g) 分布式系统的强制访问控制：对实施相同强制访问控制安全策略的分布式应用软件系统，各个场地应具有一致的主、客体标记和相同的访问规则；

h) 网络环境的强制访问控制：对分布于网络环境的应用软件系统，应根据业务应用的实际需要确定统一的或各自独立的强制访问控制安全策略。

7.1.6 安全审计

应按GB/T 20271—2006 中 6.3.2.4 的要求，从以下方面设计和实现应用软件系统的安全审计：

a) 安全审计内容：安全审计功能的设计应与用户标识与鉴别、自主访问控制、标记与强制访问控制等安全功能的设计紧密结合；

b) 安全审计处理：提供审计日志、实时报警生成，潜在侵害分析、基于异常检测，基本审计查阅、有限审计查阅和可选审计查阅，安全审计事件选择，以及受保护的审计踪迹存储和审计数据的可用性确保等功能；

c) 安全审计的统一管理：对网络环境下运行的应用软件系统，应建立统一管理和控制的安全审计机制。

7.1.7 用户数据完整性保护

应按GB/T 20271—2006 中 6.3.3.7 的要求，对在应用软件系统控制范围内存储和传输的用户数据，从以下方面设计和实现完整性保护：

a) 用户公开数据的传输保护：对应用软件系统中通过网络传输的用户公开数据，进行完整性检测，发现其完整性被破坏的情况；

b) 用户一般数据的存储保护：对在应用软件系统中存储的用户一般数据，进行完整性检测，在数据被使用前发现其完整性被破坏的情况；

c) 用户一般数据的传输保护：对应用软件系统中通过网络传输的用户一般数据，进行完整性检测，发现其完整性被破坏的情况；

d) 用户一般数据的处理保护：对应用软件系统中进行处理的用户一般数据，通过操作序列的回退等措施，实现完整性保护；

e) 用户重要数据的存储保护：对在应用软件系统中存储的用户重要数据，通过设置完整性标签等进行完整性检测，在数据被使用前发现其完整性被破坏的情况，并在完整性受到破坏时能采取相应措施进行一定恢复；

f) 用户重要数据的传输保护：对应用软件系统中通过网络传输的用户重要数据，通过设置完整性标签等进行完整性检测，发现其完整性被破坏的情况，并在完整性受到破坏时能采取相应措施进行一定恢复；

g) 用户重要数据的处理保护：对应用软件系统中进行处理的用户重要数据，通过操作序列的回退等措施，实现完整性保护。

7.1.8 用户数据保密性保护

应按GB/T 20271—2006 中 6.3.3.8 的要求，对在应用软件系统控制范围内存储和传输的用户数据，从以下方面设计和实现保密性保护：

a) 用户一般数据的存储保护：对在应用软件系统中存储的用户一般数据，通过相应安全级别/强度的密码机制或其他安全机制，实现保密性保护；

b) 用户一般数据的传输保护：对应用软件系统中通过网络传输的用户一般数据，通过相应安全级

别/强度的密码机制或其他安全机制，实现保密性保护；

c) 用户一般数据的处理保护：对应用软件系统中由用户一般数据使用的缓冲存储器及其他动态记录介质，通过在释放其使用权时对剩余信息进行删除等措施，确保不会由于动态记录介质中的剩余信息引起信息泄漏；

d) **用户重要数据的存储保护：对在应用软件系统中存储的用户重要数据，通过相应安全级别/强度的密码机制或其他安全机制，实现保密性保护；**

e) **用户重要数据的传输保护：对应用软件系统中通过网络传输的用户重要数据，通过相应安全级别/强度的密码机制或其他安全机制，实现保密性保护；**

f) **用户重要数据的剩余信息保护：对应用软件系统中由用户重要数据使用的缓冲存储器及其他动态记录介质，通过在释放其使用权时对剩余信息进行删除等措施，确保不会由于动态记录介质中的剩余信息引起信息泄漏。**

7.1.9 备份与故障恢复

应按GB/T 20271—2006 中 6.3.2.6 的要求，从以下方面设计和实现应用软件系统的备份与故障恢复：

a) 用户自我信息备份与恢复：提供用户有选择地备份重要信息的功能；当由于某种原因引起信息系统中用户信息丢失或破坏时，能提供用户按自我信息备份所保留的信息进行信息恢复的功能；

b) 增量信息备份与恢复：提供由应用软件系统定时对新增信息进行备份的功能；当由于某种原因引起应用软件系统中的某些信息丢失或破坏时，提供用户按增量信息备份所保留的信息进行信息恢复的功能。

7.1.10 系统安全性检测分析

应按GB/T 20271—2006 中 6.3.2.2 的要求，检测分析应用软件系统的安全性，并结合本级的安全性要求加以改进。

7.2 安全保证技术要求

7.2.1 安全子系统自身保护要求

7.2.1.1 SSF 物理安全保护

应按GB/T 20271—2006 中 6.3.4.1 的要求，从以下方面实现应用软件系统 SSF 的物理安全保护：

a) 物理攻击检测；

b) **物理检测自动报告。**

7.2.1.2 SSF 运行安全保护

应按GB/T 20271—2006 中 6.3.4.2 的要求，从以下方面实现应用软件系统 SSF 的运行安全保护：

a) 后门控制：系统在设计时不应留有“后门”。即不应以维护、支持或操作需要为借口，设计有违反或绕过安全规则的任何类型的入口和文档中未说明的任何模式的入口；

b) 安全系统子集结构：安全系统应是一个独立的、严格定义的应用软件系统的一个子集，并应防止外部干扰和破坏，如修改其代码或数据结构；

c) 用户和管理员安全属性定义：应提供设置和升级配置参数的安装机制，在初始化和对与安全有关的数据结构进行保护之前，应对用户和管理员的安全策略属性应进行定义；

d) 安全系统失败或中断的处理：在 SSOASS 失败或中断后，应按照失败保护中所描述的内容，保